

Políticas de Tecnología de la Información

Banco Ther S.A



UNIVERSIDAD
CATÓLICA
BOLIVIANA

Carrera: Ingeniería de Sistemas

Materia: Auditoria de Sistemas

Semestre: 9no Semestre

Integrantes:

García Aguirre Ignacio

Mattos Terán Fernanda

Pimentel Silva Jared

Quenta Ramos Ramiro

Valenzuela Rivera Mateo

Fecha: 06/04/2026

1 OBJETIVO

El presente documento tiene por finalidad establecer las directrices que regirán la gestión, operación y evolución de la tecnología de la información en el Banco Pyme Ther S.A., asegurando que los recursos tecnológicos sean administrados de forma ordenada, segura y alineada a los objetivos estratégicos de la institución. Estas políticas buscan garantizar la disponibilidad, integridad y confidencialidad de los sistemas que soportan las operaciones del banco, en estricto cumplimiento de la normativa emitida por la Autoridad de Supervisión del Sistema Financiero (ASFI) y los estándares internacionales de referencia adoptados por la institución. Su vigencia abarca el horizonte estratégico 2026–2028, período durante el cual la Gerencia de TI liderará la transformación tecnológica del banco conforme al Plan Estratégico de Tecnología de la Información (PETI-001).

2 ALCANCE

El presente documento es de cumplimiento obligatorio para la Alta Gerencia, todas las unidades organizacionales, empleados, directivos y proveedores de servicios del Banco Pyme Ther S.A., según corresponda a sus funciones y responsabilidades. Su aplicación comprende la Oficina Central ubicada en la ciudad de La Paz, donde se encuentra el Centro de Procesamiento de Datos (CPD) principal, así como las sucursales del eje central en La Paz, Cochabamba y Santa Cruz, y las agencias regionales en Oruro y Tarija. Abarca la totalidad de los procesos estratégicos, operativos y de soporte tecnológico, e involucra directamente al Área de Tecnologías de la Información y sus cuatro Subgerencias: Infraestructura y Telecomunicaciones, Desarrollo de Sistemas, Aseguramiento de Calidad, y Operaciones y Soporte, junto con la Unidad de

Administración de Datos. Todos los involucrados son responsables de su cumplimiento y correcta aplicación en el ejercicio de sus funciones diarias.

3 GLOSARIO DE TERMINOS

Termino	Significado
ASFI	Autoridad de Supervisión del Sistema Financiero de Bolivia.
COBIT	Marco de gobierno y gestión de TI (Control Objectives for Information and Related Technologies).
Core Bancario	Sistema central para la gestión de cuentas, créditos y operaciones financieras del banco.
CPD	Centro de Procesamiento de Datos, ubicado en la sede central de La Paz.
DRP	Plan de Recuperación ante Desastres (Disaster Recovery Plan).
EDR	Endpoint Detection and Response, herramienta de seguridad para detección y respuesta ante amenazas en endpoints.
MFA	Autenticación Multifactor, mecanismo que requiere dos o más factores de verificación para acceder a sistemas.
OWASP	Open Web Application Security Project, marco de referencia para el desarrollo seguro de aplicaciones web.
PETI	Plan Estratégico de Tecnología de la Información 2026–2028.
QA	Aseguramiento de Calidad (Quality Assurance), proceso formal de validación y certificación de software.

RTO	Recovery Time Objective, tiempo máximo aceptable para restaurar un sistema tras una interrupción.
RPO	Recovery Point Objective, antigüedad máxima aceptable de los datos recuperados tras una interrupción.
SAN	Storage Area Network, red de almacenamiento de alta velocidad.
VPN	Red Privada Virtual (Virtual Private Network), canal cifrado para comunicaciones seguras.
CID	Confidencialidad, Integridad y Disponibilidad, pilares de la seguridad de la información.

4 DOCUMENTOS INTERNOS RELACIONADOS

DESCRIPCIÓN	CÓDIGO
Plan Estratégico Institucional 2026–2028	PEI-001
Plan Estratégico de Seguridad de la Información 2026–2028	PESI-001
Plan Estratégico de Tecnología de la Información 2026–2028	PETI-001
Políticas de Seguridad de la Información	PSI-001
Organigrama Funcional del Área de Tecnologías de Información	ORG-TI-001
Inventario de Infraestructura de TI	INF-TI-001

Inventario de Software y Aplicaciones	INV-SW-001
Reglamento Interno de Trabajo	RIT-001
Plan de Recuperación ante Desastres (DRP)	DRP-001
Manuales de Funciones por Cargo (Área de TI)	MF-TI-001

5 DOCUMENTOS EXTERNOS RELACIONADOS

Las presentes políticas se fundamentan en los siguientes estándares y marcos internacionales: ISO/IEC 27001 como marco principal de gestión de seguridad de la información; COBIT 2019 para el gobierno y gestión de TI; NIST CSF 2.0 como marco de ciberseguridad complementario; CIS Controls v8 para controles técnicos de seguridad; OWASP Top 10 2021 para la gestión de riesgos en aplicaciones web y móviles; PCI DSS v4.0 para el estándar de seguridad de datos en pagos con tarjeta; ISO/IEC 27018 para la protección de datos personales; y la normativa vigente emitida por la ASFI, aplicable a todas las operaciones del sistema financiero boliviano.

6 DIRECTRICES GENERALES

La tecnología de la información constituye un activo estratégico fundamental para el Banco Pyme Ther S.A. Su gestión debe ser planificada, ejecutada y supervisada con el mismo rigor que se aplica a cualquier otro recurso crítico de la institución, reconociendo que los sistemas tecnológicos soportan directamente la calidad del servicio financiero ofrecido a los clientes y el

cumplimiento de las obligaciones regulatorias ante la ASFI. La Gerencia de TI ejerce el liderazgo técnico y estratégico sobre todos los recursos de tecnología de la institución, en permanente coordinación con la Gerencia de Seguridad de la Información, que actúa de manera independiente reportando directamente al Directorio. Esta separación de funciones garantiza una supervisión objetiva de los riesgos tecnológicos y una gestión alineada con los más altos estándares de gobierno corporativo. El Directorio constituye la máxima instancia de aprobación y seguimiento estratégico de las decisiones tecnológicas del banco. Las inversiones en tecnología serán evaluadas y priorizadas bajo criterios de generación de valor, mitigación de riesgos y alineamiento con los objetivos del PEI 2026–2028. Cualquier proyecto tecnológico de envergadura deberá contar con el respaldo del Comité de Tecnología de la Información antes de su ejecución.

El banco asigna los recursos humanos, financieros y tecnológicos necesarios para garantizar la operación continua, segura y eficiente de sus sistemas de información. El incumplimiento de estas políticas dará lugar a sanciones conforme al Reglamento Interno de Trabajo y la legislación boliviana vigente, sin perjuicio de las responsabilidades adicionales que pudieran derivarse de la normativa de la ASFI.

7 POLÍTICAS

7.1 GOBIERNO Y GESTION ESTRATEGICA DE TI

El Banco Pyme Ther S.A. adopta el marco COBIT 2019 como referencia principal para el gobierno de las tecnologías de la información, complementado con los estándares ISO/IEC 27001 y el NIST CSF 2.0. Este enfoque garantiza que las inversiones en TI generen valor real y contribuyan a la mitigación de

riesgos, en coherencia con el objetivo estratégico OETI-1 del PETI. La Gerencia de TI es responsable de traducir los lineamientos del Directorio en iniciativas concretas, velando porque cada proyecto tecnológico esté justificado, documentado y sometido a evaluación de riesgo antes de su aprobación formal.

El Plan Estratégico de Tecnología de la Información (PETI 2026–2028) es el instrumento rector que define la hoja de ruta tecnológica del banco. Su seguimiento y control corresponde al Comité de Tecnología de la Información, instancia que evalúa el avance de las iniciativas estratégicas, aprueba cambios de alcance y escala situaciones críticas al Directorio cuando corresponde. La Máxima Autoridad Ejecutiva (MAE) delega al Gerente de TI el seguimiento de las tendencias tecnológicas relevantes para el sector financiero y la gestión eficiente de los recursos asignados, debiendo éste informar periódicamente sobre el cumplimiento de los KPIs del PETI. Toda decisión de inversión en infraestructura, licenciamiento de software o contratación de servicios tecnológicos deberá estar alineada con el PETI vigente y documentada con un análisis de costo-beneficio y riesgo. Los contratos con proveedores tecnológicos incorporarán cláusulas de niveles de servicio (SLA), confidencialidad y cumplimiento normativo, siendo la Gerencia de TI responsable de su supervisión y la Gerencia de Seguridad de la Información, de la validación de los aspectos relacionados con la seguridad.

7.2 INFRAESTRUCUTRA Y TELECOMUNICACIONES

La Subgerencia de Infraestructura y Telecomunicaciones es responsable de mantener la disponibilidad, integridad y rendimiento de todos los componentes de la plataforma tecnológica del banco, incluyendo el Centro de Procesamiento

de Datos (CPD) de la sede central, el almacenamiento centralizado SAN, el clúster de virtualización y la arquitectura de red en estrella que conecta las sucursales y agencias con la oficina central mediante enlaces WAN gestionados.

La disponibilidad del Core Bancario y del almacenamiento SAN es un objetivo crítico de la institución. El banco establece metas progresivas de disponibilidad del 98.5% al cierre del primer año, 99% en el segundo y 99.5% al finalizar el tercer año del PETI, en coherencia con el objetivo OETI-2. Para alcanzar estas metas, la Subgerencia ejecutará las iniciativas INF-1, INF-2 e INF-3 del PETI, que contemplan el mantenimiento preventivo del CPD, la gestión de alta disponibilidad mediante el clúster de virtualización y la administración de la conectividad centralizada.

El acceso físico al CPD está restringido al personal expresamente autorizado, conforme a la Matriz de Acceso Físico definida y gestionada por la Gerencia de Seguridad de la Información en coordinación con el Encargado de Seguridad Física. El CPD cuenta con sistemas de control de acceso biométrico o por tarjeta, monitoreo continuo, y protecciones contra incendio, inundación y otras contingencias ambientales. Cualquier modificación en los controles de acceso físico requiere aprobación formal de la Gerencia de Seguridad de la Información. Las ventanas de mantenimiento programado se establecen entre las 01:00 y las 04:00 horas, con el fin de minimizar el impacto en la operación y en la experiencia del cliente. La red corporativa del banco opera bajo una arquitectura segmentada que separa los entornos de producción, desarrollo y administración. Los firewalls y los mecanismos de segmentación son

administrados por el Administrador de Redes conforme a los lineamientos establecidos por la Gerencia de Seguridad de la Información. El uso de conexiones remotas a los sistemas del banco exige el empleo de VPN corporativa y autenticación multifactor, sin excepción. Todo cambio en la configuración de red deberá ser registrado, documentado y aprobado mediante el proceso formal de gestión de cambios.

7.3 DESARROLLO DE SISTEMAS

El banco reconoce que la calidad y seguridad del software son condición necesaria para la continuidad del negocio y la confianza del cliente. La Subgerencia de Desarrollo de Sistemas aplica metodologías ágiles en todos sus ciclos de entrega, incorporando revisiones de seguridad desde las etapas más tempranas del desarrollo, en cumplimiento del objetivo OETI-3 del PETI y la iniciativa SI-2 del PESI. Esta práctica, conocida como ciclo de vida de desarrollo seguro, asegura que los controles de seguridad no sean un añadido tardío, sino una característica intrínseca de cada entregable.

Todo desarrollo, ya sea de la Banca Web, la Aplicación Móvil o las APIs de integración del Core Bancario, deberá seguir el estándar OWASP Top 10 2021 como marco de referencia para la identificación y mitigación de riesgos de seguridad en aplicaciones. Los componentes y librerías de terceros serán evaluados antes de su incorporación y mantenidos actualizados durante todo su ciclo de vida. El Arquitecto de Software es responsable de velar por la coherencia de la arquitectura de microservicios y la estandarización de las APIs que integran el Core, conforme a la iniciativa DEV-2 del PETI.

Ningún desarrollo podrá ser desplegado en el entorno de producción sin haber superado las etapas formales de aseguramiento de calidad y certificación de

seguridad definidas en las iniciativas QA-1 y QA-2 del PETI. Esta exigencia aplica tanto a los desarrollos internos como a las actualizaciones provenientes de terceros. La meta institucional es que el 80% de los proyectos de software cuenten con certificación de QA al tercer año del PETI, en coherencia con el objetivo OEI-5 del Plan Estratégico Institucional. Los entornos de desarrollo, pruebas y producción deberán mantenerse estrictamente separados, con accesos diferenciados y controlados para cada perfil de usuario.

7.4 ASEGURAMIENTO DE CALIDAD

La Subgerencia de Aseguramiento de Calidad opera como instancia independiente dentro del proceso de entrega de software, garantizando que todo cambio en los sistemas del banco sea debidamente probado y certificado antes de su pase a producción. Esta función es estratégica para el banco, ya que la meta del PETI establece que el porcentaje de fallos detectados en el entorno de QA en comparación con producción supere el 80% en el primer año, el 90% en el segundo y el 95% en el tercer año.

El Encargado de QA liderará la implementación del proceso de QA continuo, que incluye la automatización de pruebas de regresión y estrés mediante herramientas que permitan detectar defectos de manera temprana y sistemática. El Encargado de Certificación, por su parte, será responsable de la validación formal de los criterios de seguridad y funcionalidad de cada entregable, actuando como la última línea de verificación antes del despliegue en producción. Ambos roles trabajan en estrecha coordinación con la Gerencia de Seguridad de la Información para asegurar que los estándares de seguridad definidos en el PESI sean efectivamente verificados en cada ciclo de entrega. Toda aplicación deberá someterse, como mínimo, a las siguientes pruebas

antes de su aprobación para producción: revisión de código estático, pruebas de vulnerabilidades dinámicas, evaluación de componentes de terceros y pruebas de rendimiento bajo carga. Los resultados de estas evaluaciones deberán quedar debidamente documentados en el expediente de certificación del proyecto, constituyendo evidencia auditada disponible para revisión por parte de la Auditoría Interna o la ASFI cuando sea requerido.

7.5 OPERACIONES Y SOPORTE

La Subgerencia de Operaciones y Soporte es responsable de garantizar el funcionamiento continuo de los sistemas en producción, la gestión de accesos de usuarios y la ejecución de la política de respaldos y recuperación del banco. Su labor es transversal a todas las áreas de TI y constituye el soporte operativo cotidiano sobre el que descansa la disponibilidad de los servicios financieros del banco.

El control de accesos a los sistemas se rige por los principios de mínimo privilegio y segregación de funciones. El Encargado de Gestión de Accesos administra el ciclo de vida completo de las credenciales de usuario, incluyendo su creación, modificación, revisión periódica y baja oportuna. Está terminantemente prohibido compartir credenciales o utilizar accesos de terceros para operar en los sistemas institucionales. La autenticación multifactor (MFA) es obligatoria para todos los accesos remotos y para los usuarios con perfiles de acceso a sistemas críticos, en coherencia con la iniciativa OPS-1 del PETI y el objetivo OESI-4 del PESI. La meta institucional establece alcanzar el 100% de usuarios con roles críticos habilitados con MFA al tercer año del PETI.

La política de respaldos es un elemento central de la continuidad operativa del banco. Los respaldos de bases de datos financieras y sistemas críticos son obligatorios y se ejecutan conforme al esquema definido en la iniciativa OPS-2 del PETI, bajo la responsabilidad del Operador de Backup y Continuidad. Los respaldos deben ser verificados periódicamente en cuanto a su integridad y capacidad de restauración, constituyendo esta verificación un control auditado. El banco define como objetivos de recuperación un RTO menor a 8 horas en el primer año, menor a 6 horas en el segundo y menor a 4 horas en el tercer año, con pruebas de simulación de Disaster Recovery realizadas semestralmente.

7.6 ADMINISTRACIÓN DE DATOS

La Unidad de Administración de Datos tiene la responsabilidad de centralizar, organizar y automatizar los flujos de información del banco, asegurando que los datos estén disponibles con la calidad y oportunidad necesarias para la toma de decisiones institucionales y el cumplimiento de los reportes regulatorios exigidos por la ASFI. Esta función se sustenta en los objetivos OETI-5 y DATA-1 del PETI, que contemplan la implementación de flujos ETL automatizados y la optimización de los motores de bases de datos Oracle y SQL Server.

La meta del PETI en materia de gestión de datos establece que la generación de reportes regulatorios pase de una frecuencia semanal en el primer año a una frecuencia diaria en el segundo, y en tiempo real al cierre del tercer año.

Este objetivo requiere una estrecha coordinación entre la Unidad de Administración de Datos, la Subgerencia de Infraestructura y la Gerencia de TI para garantizar que la infraestructura de procesamiento soporte el incremento progresivo de la carga de trabajo analítica sin comprometer el rendimiento de los sistemas transaccionales.

El acceso a las bases de datos de producción está restringido al personal con funciones explícitas de administración de datos, previa autorización formal de la Gerencia de TI y registro en el sistema de control de accesos. Cualquier consulta o extracción de información con fines analíticos debe realizarse sobre entornos de réplica o sobre estructuras de datos preparadas para ese propósito, evitando el acceso directo a los sistemas transaccionales en producción. La información de carácter financiero y los datos personales de los clientes son tratados conforme a la clasificación de información definida en las Políticas de Seguridad de la Información (PSI-001) y las normativas aplicables de la ASFI.

7.7 GESTIÓN DE CAMBIOS TECNOLÓGICOS

Todo cambio en los sistemas de información del banco, ya sea en infraestructura, software, configuración de red o parámetros de base de datos, deberá seguir un proceso formal de gestión de cambios que contemple las etapas de solicitud, evaluación de impacto, aprobación, implementación y verificación post-implementación. Este proceso busca garantizar la trazabilidad de las modificaciones y proteger la estabilidad de los entornos de producción.

Los cambios se clasifican en estándar, normal y de emergencia según su naturaleza y urgencia. Los cambios estándar, que corresponden a modificaciones rutinarias de bajo riesgo y procedimiento conocido, pueden ser ejecutados sin aprobación previa, aunque deben quedar documentados. Los cambios normales requieren evaluación formal del riesgo y aprobación por parte del responsable de área correspondiente y la Gerencia de TI antes de su implementación. Los cambios de emergencia, motivados por incidentes críticos que afectan la operación del banco, pueden implementarse de inmediato, pero

deben ser documentados y revisados formalmente dentro de las 24 horas siguientes a su ejecución. En todos los casos, la Gerencia de Seguridad de la Información deberá ser informada de los cambios que afecten a sistemas críticos o controles de seguridad.

7.8 CONTINUIDAD TECNOLÓGICA Y RECUPERACIÓN ANTE DESASTRES

La continuidad tecnológica es un pilar estratégico del Banco Pyme Ther S.A. Los sistemas críticos, incluyendo el Core Bancario y los canales digitales, deben mantenerse operativos con la máxima disponibilidad posible, estableciendo ventanas de mantenimiento programadas que minimicen el impacto en los clientes. El Plan de Recuperación ante Desastres (DRP-001) es el instrumento que define los procedimientos, responsabilidades y tiempos de recuperación ante escenarios de interrupción grave, y debe mantenerse actualizado, documentado y probado con regularidad.

La Gerencia de Seguridad de la Información y la Subgerencia de Operaciones y Soporte son corresponsables de coordinar los simulacros semestrales de Disaster Recovery, cuyos resultados deben quedar registrados y evaluados para identificar oportunidades de mejora en los procedimientos y en los tiempos de recuperación. Los resultados de estos simulacros son comunicados al Directorio como parte del reporte de gestión de riesgos operativos. Cualquier desviación significativa respecto a los objetivos de RTO y RPO definidos deberá conllevar un plan de mejora formal con responsables y plazos definidos.

7.9 SEGURIDAD TECNOLÓGICA INTEGRADA

La seguridad tecnológica no es responsabilidad exclusiva de la Gerencia de Seguridad de la Información: es una responsabilidad compartida que atraviesa

todas las capas de la organización de TI. Cada Subgerencia debe incorporar los controles de seguridad definidos en el PESI como parte integral de sus procesos y no como una verificación externa al final del ciclo. Esta integración es la que da sentido al concepto de seguridad por diseño que el banco promueve en su estrategia tecnológica. El despliegue de herramientas EDR en los endpoints de la red corporativa es una iniciativa definida en el PEI (I4.2) y en el PESI (OESI-3), orientada a la detección temprana de intrusiones y la contención de incidentes de ciberseguridad. La gestión de estas herramientas es coordinada entre la Subgerencia de Infraestructura y la Gerencia de Seguridad de la Información, asegurando una visión unificada del estado de seguridad de la plataforma. La meta del PESI establece que el 95% de los incidentes críticos sean contenidos en menos de 4 horas al tercer año del horizonte estratégico.

El banco realiza pruebas de penetración periódicas coordinadas por la Gerencia de Seguridad de la Información, con el fin de identificar vulnerabilidades en los sistemas antes de que puedan ser explotadas por actores externos. Los hallazgos de estas pruebas son clasificados por nivel de criticidad y gestionados mediante planes de remediación formales con plazos definidos. La Auditoría Interna tiene acceso a los registros de estas pruebas y a los planes de remediación como parte de su función de evaluación del SGSI.

8 INCUMPLIMIENTOS

El incumplimiento de las presentes políticas por parte de cualquier empleado, directivo o proveedor del Banco Pyme Ther S.A. será sancionado conforme a lo establecido en el Reglamento Interno de Trabajo (RIT-001) y la legislación boliviana vigente, sin perjuicio de las responsabilidades legales adicionales que

podieran derivarse de la naturaleza del incumplimiento. Los casos de incumplimiento grave que comprometan la seguridad de los sistemas, la continuidad del negocio o el cumplimiento normativo ante la ASFI serán escalados al Directorio y, cuando corresponda, comunicados al regulador. La Gerencia de TI y la Gerencia de Seguridad de la Información tienen la obligación de reportar oportunamente cualquier incumplimiento relevante a las instancias correspondientes, garantizando la trazabilidad del proceso sancionatorio.

9 APROBACIÓN

El presente documento ha sido elaborado por la Gerencia de Tecnologías de la Información del Banco Pyme Ther S.A., con la revisión de la Gerencia de Seguridad de la Información y la Auditoría Interna. Ha sido aprobado por las instancias correspondientes, momento a partir del cual entra en vigencia y es puesto a disposición de todo el personal dependiente del Banco Pyme Ther S.A.

Elaborado por	Revisado por	Aprobado por
Gerencia de TI	Gerencia de Seguridad de la Información	Gerente General / Directorio
Fecha: 06/04/2026	Fecha: 06/04/2026	Fecha: 06/04/2026